

Ciberespionaje con Follina: la campaña de TA413

Cómo un señuelo dirigido, una vulnerabilidad de Microsoft y el malware LOWZERO formaron una cadena de ataque.

Un APT, un objetivo: la comunidad tibetana

Caso de estudio: la campaña de mayo de 2022 que explotó Follina.

APT

Actor avanzado y persistente: ataca objetivos concretos y se mantiene activo durante mucho tiempo.

TA413

Grupo vinculado a China, también conocido como LuckyCat. Ataca a la comunidad tibetana desde al menos 2020.

Qué veremos

Sus TTPs, descritas con MITRE ATT&CK, y el malware que despliega: LOWZERO.

Un señuelo hecho a medida de la comunidad tibetana

Falsa subvención para fotografías tibetanas. Suplantación de la Administración Central Tibetana.

Enlaces

Enlaces a documentos

RAR

Un Word malicioso y una imagen PNG

Objetivo: que la víctima interactúe con el documento.



Follina (CVE-2022-30190) convirtió un documento en ejecución de comandos

Fallo en MSDT, la herramienta de diagnóstico de Windows.

01

Word

Recuperaba un HTML remoto

02

HTML remoto

Usaba el esquema `ms-msdt`

03

MSDT

Ejecución de comandos

Follina es la vulnerabilidad, PowerShell la herramienta, LOWZERO el malware.

Explotada por TA413 el 30 de mayo de 2022, poco después de hacerse pública.

Acceso inicial: el phishing abrió la puerta

T1566.002

Enlace de spearphishing

T1566.001

Archivo adjunto malicioso

Contenido alojado en infraestructura externa, incluido Google Firebase.

Una cadena de técnicas coordinadas, no un simple documento infectado.

Del documento a LOWZERO en cuatro pasos

01 El documento recupera **poc.html** desde **65.20.75[.]158** y activa Follina (T1203)

02 PowerShell en Base64 descarga **0524x86110.exe** (T1059.001, T1105)

03 El cargador despliega LOWZERO e inyecta una DLL en **rundll32.exe** (T1055.001)

04 LOWZERO envía datos del sistema por **TCP 110** con un protocolo que imita TLS

Limitación: no se recuperaron todos los módulos adicionales.

TTPs de TA413 en esta campaña

Resumen de tácticas y técnicas según MITRE ATT&CK.

Táctica	Qué hizo TA413	Técnica ATT&CK
Acceso inicial	Spearphishing con enlace y con adjunto malicioso	T1566.002 · T1566.001
Infraestructura	Contenido alojado en servicios legítimos como Google Firebase	T1583.006
Ejecución	Documento de Word que explota Follina	T1203
Ejecución	PowerShell con comando en Base64	T1059.001
Comando y control	Descarga del cargador 0524x86110.exe	T1105
Evasión de defensas	Inyección de una DLL en rundll32.exe	T1055.001
Comando y control	Datos por TCP 110 con un protocolo que imita TLS	T1571 · T1001.003



TA413: actor vinculado a China contra la comunidad tibetana

Documentado por Proofpoint en 2020.

Malware asociado

Sepulcher · FriarFox · LOWZERO

Atribución basada en víctimas, se uelo, infraestructura y capacidades.

Evidencia técnica y atribución son cosas distintas; el impacto final no es público.

Una cadena coordinada exige defensa en capas

Aplicar parches de seguridad

Qué corta: Frena la explotación de Follina (CVE-2022-30190) · T1203

Vigilar procesos iniciados por Office

Qué corta: Detecta a Word lanzando msdt.exe o PowerShell · T1203, T1059.001

Detectar usos anómalos de PowerShell

Qué corta: Comandos en Base64 y descargas de ejecutables · T1059.001, T1105

Monitorizar conexiones de red

Qué corta: TCP 110 inusual y tráfico que imita TLS · T1571, T1001.003

Formar a los usuarios frente a los se ñuelos (T1566) completa la defensa.

Conclusiones

01

TA413 reutiliza tácticas probadas y adopta rápido lo nuevo: explotó Follina poco después de hacerse pública.

02

LOWZERO es una puerta trasera: recibe módulos adicionales solo si el equipo infectado interesa al atacante.

03

Parchear, vigilar Office y PowerShell y monitorizar la red corta la cadena en varios puntos.

Fuentes

Recorded Future (Insikt Group), «Chinese State-Sponsored Group TA413 Adopts New Capabilities in Pursuit of Tibetan Targets», sept. 2022.

Proofpoint, informes sobre TA413 y Follina, 2020-2022.

The Hacker News, artículo sobre TA413 y LOWZERO, sept. 2022.

MITRE ATT&CK, attack.mitre.org.

Microsoft MSRC, CVE-2022-30190.